

Brian J. Scott

hello@briscosec.io · github.com/therealartifex · linkedin.com/in/brian-scott-1765b9aa

PROFESSIONAL SUMMARY

Product security engineer with four years at Cisco's Advanced Security Initiatives Group (ASIG) performing offensive security assessments across cloud, container, network, web application, and AI/LLM attack surfaces, with findings integrated into Cisco's Secure Development Lifecycle. Co-author of CVE-2022-38060, published by Cisco Talos. Depth in vulnerability research, exploit development, penetration testing, cloud and Kubernetes security, and AI/LLM security including prompt injection and guardrail bypass. Develops security tooling and data pipelines in Python, C++, and ClickHouse, and operates a self-built detection engineering lab. Certified GXPn, GCPN, OSCP, and CRT0.

EXPERIENCE

Security Research Engineer

Apr. 2022–Mar. 2026

Cisco Systems, Inc. – Advanced Security Initiatives Group (ASIG)

- Performed crystal-box product security assessments over four years across enterprise network, cloud, web application, and AI products; built threat models and adversary-perspective attack models, then chained vulnerabilities from initial access to maximum impact; remediation guidance integrated into Cisco's Secure Development Lifecycle.
- Co-authored **CVE-2022-38060**, a local privilege escalation via sudoers PATH manipulation in OpenStack Kolla enabling root command execution from within a container.
- Assessed AI/LLM product security via prompt injection and guardrail bypass, demonstrating unauthorized data access paths through an LLM-integrated production product.
- Identified a complete JWT signature verification bypass through static analysis and source code review, enabling authentication bypass and privilege escalation across every protected endpoint of a web application.
- Assessed cloud and Kubernetes container security: identified service account tokens reachable via an unauthenticated local socket and duplicated to world-readable paths; delivered secrets management and RBAC scope reduction guidance.
- Reviewed transport security of a distributed network security platform; confirmed unauthenticated RPC channels by passive capture of plaintext credentials and demonstrated unauthenticated injection of arbitrary firewall rules into hardware-accelerated enforcement.
- Applied dynamic instrumentation with Frida to hook Windows cryptographic APIs during live authentication, tracing a cleartext credential exposure window through a two-stage TPM decryption flow; developed proof-of-concept exploits and tooling in Go, C++, and PowerShell, and presented findings to product engineering teams and division-wide technical readouts.

Independent Security Researcher

Apr. 2021–Present

Southwest Valley Research Group

- Research threat actor tactics, techniques, and procedures across breach data, stealer logs, and criminal forums, applying threat intelligence analysis to actor and infrastructure profiling.
- Built and operate a threat intelligence data pipeline spanning hundreds of datasets: collection, ingestion, parsing, normalization, and analysis in Python with a ClickHouse analytical backend using columnar storage, zstd compression, and tiered retention.
- Built a segmented research and detection engineering lab: seven-VLAN default-deny network, Zeek and Suricata sensors feeding ClickHouse and Grafana, an SSH certificate authority, and single sign-on with hardware-backed multi-factor authentication.
- Conduct pro bono open-source intelligence and public records research supporting an attorney's casework.

Penetration Tester

2021

Gray Station CPAs PC, Gray, TN – Contract Engagement

- Performed network and physical penetration testing, social engineering, and OSINT reconnaissance for a defined-scope assessment; delivered a formal report with risk-prioritized remediation guidance and security awareness training recommendations.

- Discovered broadcast amplification and packet replay vulnerabilities in a proprietary industrial SCADA protocol through network traffic analysis; reported findings led to remediation in deployed water treatment and energy infrastructure.
- Developed PLC programming software in C++ and MFC for industrial control system product lines.

SELECTED PROJECTS AND OPEN SOURCE

- **CVE-2022-38060 – OpenStack Kolla** (CVSS 3.1: 7.8, High): Co-discovered local privilege escalation enabling arbitrary root command execution from within a containerized OpenStack deployment. TALOS-2022-1589
- **hashcat – Native Cracking Module** (merged upstream): Contributed a native module for Ruby on Rails RESTful Authentication hashes, eliminating the manual preprocessing previously required for the hash type. PR #2914
- **fff – Fast Find in Files**: Multi-threaded C++ search tool using SIMD/AVX intrinsics and equal-chunk work distribution across cores; outperforms grep at all tested file sizes. github.com/therealartifex/fff
- **Malware Development and EDR Evasion Research**: Built a C++ shellcode loader that retrieves an encoded payload over the network, decodes it in memory, and executes from an executable page without writing to disk; evaded antivirus detection of a known payload through the in-memory execution model.
- **briscosec.io – Security Research Writing**: Personal site publishing technical writeups on security research, tooling, and infrastructure design. <https://briscosec.io>

EDUCATION

Bachelor of Science, Computer Science

2018

Network Security Concentration · Minor in Applied Sciences

LeTourneau University, Longview, TX

TexSAW Capture the Flag (UT Dallas): competed three of four years; team placed 1st, 2017.

CERTIFICATIONS AND TRAINING

- GIAC Exploit Researcher and Advanced Penetration Tester (GXPN) – 2024
- GIAC Cloud Penetration Tester (GCPN) – 2022
- Offensive Security Certified Professional (OSCP) – 2022
- Zero-Point Security Certified Red Team Operator (CRTO) – 2021
- Sektor7 Institute: Red Team Operations – Malware Development, EDR Evasion, and Windows Privilege Escalation

TECHNICAL SKILLS

Offensive Security: Vulnerability research; exploit development; penetration testing (network, web application, physical); red teaming and adversary emulation (Cobalt Strike); social engineering; malware development; EDR evasion; dynamic instrumentation (Frida); reverse engineering; Burp Suite, Nuclei, Metasploit, Pacu.

Application and Product Security: SDLC; threat modeling; secure code review; static application security testing (Semgrep, Trufflehog); authentication and authorization review (JWT, OIDC, RBAC).

Cloud and Infrastructure Security: AWS; Kubernetes and container security; OpenStack; secrets management; IAM; PKI; TLS/mTLS; MFA/WebAuthn; 802.1X; Active Directory; Keycloak/OIDC; network segmentation and firewall policy; Proxmox VE; Linux; FreeBSD; Windows Server.

AI/LLM Security: Prompt injection; guardrail and safety filter bypass; agentic pipeline attack surface assessment; RAG pipeline design; AI-assisted static code analysis in vulnerability research workflows.

Detection Engineering and Threat Intelligence: Network security monitoring (Zeek, Suricata); SIEM (Splunk, Elasticsearch); ClickHouse; Grafana; CTI; threat actor attribution; breach data analysis; OSINT; digital forensics (X-Ways); Maltego.

Programming: C/C++ (Windows API, SIMD/AVX), Python, Go, C#, PowerShell, SQL, Bash.